

ISMS Scope and Statement of Applicability (ISO/IEC 27001:2022)

SECTION 04-compliance-ksa TYPE document STATUS **draft** OWNER Founder
UPDATED 2026-08-18

This is a readiness artefact, not a certification claim. Fly GACA is **not** ISO/IEC 27001 certified and does not represent itself as such. `information-security-policy.docx` §14 targets an ISO 27001 readiness assessment in **Year 2 (2027)**, consistent with `compliance-roadmap.md`. This document exists so that work starts from a defined scope and a control inventory rather than from nothing — and so that B2B buyers and investors asking "what is your ISMS scope?" get a real answer today.

ISO/IEC 27001 is **voluntary**. PDPL and SDAIA remain the binding regimes.

1. Why this exists when a security policy already does

`information-security-policy.docx` is a substantive 15-section policy — asset classes, RBAC, cryptography, endpoint, network, incident severity, backup, training. It is a good policy.

It is not an ISMS. An ISMS additionally requires:

ISO clause	Artefact	Present before this document
4.3	A defined scope statement	No
6.1.2	A documented risk assessment methodology and its output	No
6.1.3 / Annex A	A Statement of Applicability	No

Those three are exactly what external parties ask for. This document supplies the first and third; `cyber-risk-assessment-2026-08.md` supplies the second.

2. Clause 4.3 — Scope statement

The Information Security Management System covers the design, development, and operation of Fly GACA's educational aviation platform: the `flygaca.com` web application and its Firebase Cloud Functions backend; the Captain Adel AI service at `captadel.com`; the supporting Google Cloud tenancy (Firestore, Authentication, Cloud Functions, Gemini inference); and the source repositories and CI/CD pipelines that build and deploy them. The ISMS covers all personal data of learners and partner-academy cadets processed by those systems.

Exclusions, with justification — the part auditors and buyers actually read:

Excluded	Justification
The EU VPS (Hostinger, Paris)	Serves the public regulatory corpus only ; never processes personal data (<code>06-operations-it/hosting-facts.md</code>)
Moyasar's cardholder data environment	Operated by Moyasar as a PCI DSS compliant processor; Fly GACA stores/processes/transmits no cardholder data (<code>pci-dss-scope-and-saq-determination.md</code>)
Apple IAP / RevenueCat billing	Operated by Apple; outside Fly GACA's control boundary
Physical premises and data centres	The company operates no office or data centre; all infrastructure is cloud-hosted (drives the A.7 exclusions below)

Known scope caveat, stated rather than hidden: compute currently runs in `me-central1` (Doha) while data rests in `me-central2` (Dammam). This is inside ISMS scope, is an accepted interim with a documented migration path, and is carried as risk **CR-09**.

3. Clause 6.1.2 — Risk methodology

Not restated here. The methodology, scale, threat sources, and risk determination are in `cyber-risk-assessment-2026-08.md`, which uses NIST SP 800-30 Rev 1 and a 1–5 likelihood × impact scale aligned to `09-investor-relations/risk-register.xlsx`. A second, divergent scale would be worse than none.

4. Statement of Applicability

ISO/IEC 27002:2022 restructured Annex A into **93 controls across four themes**. Status uses: **Implemented** (a document or mechanism exists), **Partial**, **Planned**, **N/A** (with justification — required).

4.1 Coverage summary

Theme	Controls	Implemented	Partial	Planned	N/A
A.5 Organizational	37	21	9	5	2
A.6 People	8	4	2	1	1
A.7 Physical	14	1	0	0	13
A.8 Technological	34	16	10	8	0
Total	93	42	21	14	16

These are the founder's initial determinations for planning. **Per-control justification text is the outstanding work** and is required before any certification attempt — see §5.

4.2 Not applicable — the justifications that must hold

Control(s)	Justification
A.7.1–A.7.6, A.7.8, A.7.11–A.7.14 (13 of A.7)	The company operates no office, facility, or data centre. There is no physical perimeter, no secure area, no equipment siting, no supporting utilities, and no on-premises media to dispose of. All infrastructure is cloud-hosted and covered by the providers' own certifications
A.6.4 Disciplinary process	No employees at present. Becomes applicable on first hire — flag in 05-people/
A.5.9 (partial scope)	Asset inventory applies, but only to cloud and information assets

A.7.7 (clear desk / clear screen) is retained as **Implemented** because it applies to the founder's workstation, which is in scope.

4.3 Controls where the ISP already carries the weight

information-security-policy.docx is the implementing document for the bulk of A.5 and much of A.8 — access control (A.5.15–A.5.18), cryptography (A.8.24), backup (A.8.13), logging (A.8.15), malware (A.8.7), and incident management (A.5.24–A.5.28). business-continuity-and-disaster-recovery-plan-bcp-dr.docx implements A.5.29–A.5.30. vendor-management-policy.docx, procurement-policy.docx, and sub-processor-list-and-dpa-register.docx together implement the supplier set A.5.19–A.5.23. 01-governance/SECURITY.md implements A.5.5–A.5.6 (contact with authorities and special interest groups) and vulnerability disclosure.

4.4 Where the real gaps are — the 2022-new controls

The five controls introduced in the 2022 revision are, unsurprisingly, where a young ISMS is thinnest. Each maps to a live finding:

Control	Status	Gap
A.5.7 Threat intelligence	Planned	No structured intake. Dependabot on three of five repos is the only signal
A.5.23 Cloud services security	Partial	Vendor policy covers procurement, but there is no configuration baseline for the Google Cloud tenancy — and single-cloud concentration (PC-2 in the risk assessment) is unaddressed
A.8.9 Configuration management	Partial	Infrastructure config is in-repo and reviewed, but CSP is defined in four places that disagree (see the PCI memo) — a configuration-management failure in the literal sense
A.8.16 Monitoring activities	Partial	Health checks and deploy notifications exist; there is no security monitoring or alerting
A.8.28 Secure coding	Partial	Code review and CI gates exist. JS/TS SAST does not run , and the 2026-08-18 sweep found five credentials still in git history — both are A.8.28 gaps

4.5 One control worth calling out as a strength

A.8.24 Use of cryptography. `06-operations-it/secrets-and-keys-placement.md` deliberately records secret *names and locations only*, never values — and the native app's remote corpus channel is gated on a **detached Ed25519 signature that fails closed** in every failure mode. That is a stronger position than most organisations at this stage, and the discipline should be preserved rather than relaxed for convenience.

5. Outstanding work before certification is realistic

1. Write per-control justification text for all 93 controls (this document has the determinations, not yet the justifications).
2. Close the five A.5.7 / A.5.23 / A.8.9 / A.8.16 / A.8.28 gaps in §4.4.
3. Establish the Clause 9 machinery — internal audit, management review, corrective action — none of which exists yet.
4. Define ISMS objectives with measures (Clause 6.2).
5. Revisit A.6.4 and the People theme on first hire.

Realistically these support the **2027** readiness target already recorded, not an earlier one.

Related: `information-security-policy.docx`, `cyber-risk-assessment-2026-08.md`, `pci-dss-scope-and-saq-determination.md`, `business-continuity-and-disaster-recovery-plan-bcp-dr.docx`, `vendor-management-policy.docx`, `01-governance/SECURITY.md`, `06-operations-it/secrets-and-keys-placement.md`.